

Semivra Libellus POS - Engineering Session Report

Generated 2026-06-05 Branch security/hardening-p1-p3 PR #1 21 commits

This report documents every change made during the hardening/QA/feature session, in full detail, so it can be reviewed independently of the chat transcript.

1. Headline

A single working branch (security/hardening-p1-p3, PR #1 against main) containing **21 commits**: a full security-hardening pass, a breaking dual-token authentication rewrite, the user-reported bug fixes, accounting/ledger corrections, new operator features, documentation, ops tooling, and a toolchain upgrade.

Verification status (static): server node --check OK vitest **81/81** client vite build clean npm audit **0 vulnerabilities** (server and client) GitHub Actions CI **green**.

Not yet done (requires a running environment / your action): end-to-end browser verification of the breaking auth change, then merge + production deploy.

2. Dependencies changed

Server (added): helmet, zod, cookie-parser, @sentry/node

Client: swapped npm xlsx -> patched SheetJS 0.20.3; added @playwright/test (dev); upgraded vite 5 -> 8 + @vitejs/plugin-react 6

3. New files created

File	Purpose
`client/src/lib/auth.js`	In-memory access-token store + silent refresh
`client/src/lib/usePagination.js`	Reusable client-side pagination hook
`client/src/components/Pager.jsx`	Pagination control component
`client/e2e/auth.spec.js`, `checkout.spec.js`	Playwright E2E specs
`client/playwright.config.js`	E2E config (chromium + tablet)
`server/lib/units.test.js`	Unit tests incl. new `effectiveDisplay`
`scripts_temp/md_to_pdf.cjs`	Markdown -> PDF renderer
`AUDIT_OVERVIEW.md`	Competitive/feature/vulnerability audit
`MANUAL.md` + `Semivra_Libellus_Manual.pdf`	User manual + tutorial
`GO_LIVE.md`	Deploy + rollback runbook

4. Security hardening (server)

- **Edge:** app.disable('x-powered-by'), app.set('trust proxy', 1) (correct rate-limit IP behind Railway), **Helmet** (HSTS preload, nosniff, frameguard, referrer policy; CSP off for JSON API; CORP cross-origin for the SPA).
- **Passwords:** bcrypt cost **10 -> 12** (OWASP 2025 minimum), all hash sites via a BCRYPT_ROUNDS constant.

- **Injection:** `escapeRegex()` helper - fixed **ReDoS / regex-injection** on `POST /api/inventory` and `POST /api/users` (user input went straight into new `RegExp`). NoSQL-object injection on login closed by Zod string typing.
- **Validation / mass-assignment (BOPLA):** Zod `validate()` middleware (strips unknown keys + 422 field errors) on login, user-create, addon, product, combo, discount, role, modifier-group create routes. `POST /api/roles` tightened to superadmin.
- **Error handling:** centralized error handler + 404 fallback; **~87 route catch blocks** gated behind `IS_PROD` so internal `err.message/stack` never leak in production.
- **Rate limiting:** baseline `/api` limiter (300/min) on top of the existing login (10/15min) and order (60/min) limiters.
- **XSS:** kitchen-ticket print window now escapes all dynamic values (customer name, order notes, item names - all customer-suppliable).
- **Resilience:** `mongoose.connect` timeouts (fail fast); `uncaughtException/unhandledRejection` now drain + `exit(1)` for a clean supervisor restart; `console.*` -> structured `pino`.
- **Dependencies:** server `npm audit fix` -> 0 vulns; client `xlsv` HIGH (prototype pollution + ReDoS) replaced with patched `SheetJS`.

5. Authentication rewrite - ****BREAKING****

Replaced the single long-lived JWT-in-localStorage model with a dual-token system:

- **Access token:** 15-minute JWT, held in client memory only (not localStorage -> not XSS-exfiltratable).
- **Refresh token:** opaque random secret in an **httpOnly, Secure, SameSite cookie**; stored sha256-hashed in a new `RefreshSession` collection (TTL auto-purge) so it can be **revoked server-side**.
- **Endpoints:** `POST /api/auth/refresh` (silent refresh) and `POST /api/auth/logout` (real server-side revocation). Sessions are revoked on logout, password change, role change, and account deletion.
- **CSRF:** cross-site cookie requires `SameSite=None`; `Secure` in production (Vercel Railway are different sites); compensated with an **Origin allowlist** guard on the auth routes.
- **Client:** new `lib/auth.js` (in-memory token + silent refresh + retry-on-401); both `AdminDashboard` and `SuperAdminPanel` migrated with an async refresh bootstrap and a "Restoring session..." splash.
- **Post-test fix:** refresh was changed to **non-rotating** after testing revealed that rapid page reloads fired concurrent refreshes, which token-rotation mis-read as reuse and logged the user out. It now validates + issues a fresh access token, keeps the same cookie, and slides expiry. Legacy `semivra_token/kasa_token` keys are purged from localStorage on load.

6. Bug fixes (user-reported) & accounting corrections

- **Shift cash showing PHP 0:** cash is collected at the **Preparing** transition (`amountTendered`), but the shift calc only counted **Completed** orders. Fixed to count all paid cash orders (shared `shiftCashFilter`).
- **Day-close leaving orders dangling:** auto-close and manual archive now force-cancel **Parked + Ready** orders (not just Pending/Preparing) and clear `isParked`.
- **Journal entry remove-line:** added an **X** button to delete a line in New Journal Entry (guards the 2-line minimum).
- **Revolving fund "from thin air":** fund creation now has a **Paid From** source account (Cash on Hand / Cash in Bank); the opening journal entry credits the chosen account.
- **Ledger gap (JE scan):** manual inventory **batch add/delete** now sync `stockQty`, write a `StockCard` entry, and post a balanced journal entry (4200 gain / 5100 variance). Scan confirmed every other money/inventory route already posts balanced journal entries inside MongoDB transactions.
- **General Ledger auto-refresh:** emit `erpUpdated` from 7 endpoints that didn't (manual JE, AP payment, shift-end variance, bank deposit, revolving-fund create/disburse/replenish) so the ledger updates live on every transaction.
- **Purchase Order units:** shows **kg/L** (not g/ml) via a new `effectiveDisplay()` helper (+6 unit tests).
- **Owner exclusion:** the superadmin/owner is excluded from Staff Hours, Shift History, and Cashier Variance.

7. New operator features

- **Superadmin auto-close toggle:** `autoCloseEnabled` setting - turn the midnight auto-archive on/off (superadmin only).
- **Superadmin logout:** no longer requires a register cash-count; logs out directly ("Log Out" label).
- **Mandatory staff clock-in:** non-superadmins hit a clock-in gate after login and must clock in before using the POS.
- **Staff Hours auto-load:** the sub-tab fetches automatically on open.
- **Report pagination:** client-side pagination on 7 ledger report tables (A/R, A/P, sales-by-payment, profit-by-category, menu-engineering, cashier-variance, purchase-order).

8. Tooling, CI, docs, ops

- **vite 5 -> 8** upgrade (rolldown engine; cleared the dev-server advisories -> client 0 vulns).
- **CI fix:** regenerated lockfiles so `npm ci` passes on Linux (vite8/rolldown native bindings needed `@emnapi/*` package entries the Windows install omitted). CI is now green.
- **Double-submit guard:** Place Order can no longer create duplicate orders (ref guard + disabled button + idempotency key).
- **Docs:** `AUDIT_OVERVIEW.md`, `MANUAL.md` (+PDF), `GO_LIVE.md` runbook.
- **Monitoring:** optional `@sentry/node` (inert unless `SENTRY_DSN` set).
- **PR #1** opened with a pre-merge checklist.

9. Full commit list (21)

```
dcd9604 security hardening batch 1 (helmet, zod, bcrypt-12, regex-escape, prod errors, xlsx-
0949e0d P2 hardening - Zod allowlists on create routes + safe crash handling
1140b91 P1 dual-token auth - 15m access JWT + httpOnly refresh cookie + revocation
f8eba9b scaffold Playwright auth-flow + checkout specs
75cc927 P2/P3 - error leak gate, rate limit, print XSS, db timeouts, logging
5dbd46a day-close archives parked/ready orders + journal-entry remove-line button
60a49db shift cash recognition, revolving-fund source account, batch ledger
787426a pagination on 7 ledger report tables
8208767 superadmin toggle for automatic midnight close
5bd777f exclude owner from staff hours, shift history & cashier variance
df96b9d add complete user manual & quick-start tutorial
5429c03 show kg/L (not g/ml) in Purchase Order suggestion
29c9547 auto-refresh general ledger on every journal transaction
3c7e677 generate manual PDF
d27d1cf rewrite md->pdf renderer for readable manual
6ff8be8 go-live/rollback runbook + optional Sentry monitoring
2364cc9 upgrade vite 5->8 + plugin-react 6
edbc2fe prevent duplicate orders from double-tapping Place Order
5d3ed13 regenerate lockfiles so npm ci passes on Linux
42b6de8 non-rotating refresh (fixes F5-spam logout) + purge legacy tokens
db71dac superadmin logout skips count; staff must clock in; staff hours auto-loads
```

10. What remains (not in this session)

1. **End-to-end browser verification** of the breaking auth change (local/staging walkthrough in `GO_LIVE.md` 2).
2. **Production env** setup (`ALLOWED_ORIGINS`, `NODE_ENV=production`, `VITE_API_URL`, etc.) then **merge + deploy**.
3. **Pilot** (run Kasa Lokal live 2-4 weeks) + **accountant review** of BIR/Non-VAT correctness.
4. **Sell-as-product** layer: per-instance vs multi-tenant decision, legal, pricing/billing, support.
5. **Optional/deferred:** split the 4,600-line `AdminDashboard.jsx`, broader integration test harness.

11. Caveats for reviewers

- Nothing is merged to `main`; it all lives on PR #1.
- The dual-token auth change is breaking and unverified in a browser - it's the #1 review focus (1140b91 + 42b6de8).
- Large diffs in `AdminDashboard.jsx` / `OrdersTab.jsx` / `LedgerTab.jsx` are partly pre-existing untracked tab-split work that got committed alongside; the session's actual edits within them are targeted.
- The user's own commit d1615cc "hardening the app" (their working-tree changes) is also on the branch.

